Profils utilisateurs - pili-pos

Le Manuel de certification SCE 2.0 (Introduction, p.9) impose **trois profils d'accès** distincts au système :

- **Gérant / Technicien** ("Manager / Technicien")
- **Serveur**
- **Apprenti**

Le présent document établit la correspondance entre ces profils attendus par le SPF Finances et les rôles techniques implémentés dans `crates/pos-core/src/user.rs`.

1. Correspondance des profils

Profil SCE 2.0	Rôle technique `pili-pos`	Code source
Gérant / Technicien	`UserRole::Admin`	`crates/pos-core/src/user.rs:6`
Serveur	`UserRole::Cashier`	`crates/pos-core/src/user.rs:7`
Apprenti	`UserRole::Waiter`	`crates/pos-core/src/user.rs:8`

Chaque utilisateur du POS est stocké dans la table `users` (`crates/pos-db/src/schema.rs`) avec : - son numéro INSZ à 11 chiffres (clé primaire, validé par `validate_insz` dans `crates/pos-core/src/user.rs:51`) ; - son rôle (`admin` / `cashier` / `waiter`) ; - un hash bcrypt de son code PIN (facultatif) ; - un drapeau `presence_only` (profil « Présence seule », §2.4) : 0 pour tout employé qui utilise la caisse, 1 pour le personnel qui n'y a pas accès ; - un drapeau `active` pour désactiver un utilisateur sans le supprimer (la suppression n'est autorisée que pour les utilisateurs n'ayant jamais effectué d'événement fiscal - voir §III.C).

2. Capacités par profil

2.1 Gérant / Technicien (`Admin`)

Accès complet. Concrètement, peut :

- Effectuer toutes les opérations d'un Serveur (ci-dessous).
- Générer un rapport X (à tout moment de la journée).
- Générer un rapport Z (clôture de journée fiscale).
- Saisir un Money-in / Money-out (Événement F - fonds de caisse, pourboires, retrait).
- Ouvrir le tiroir-caisse hors-vente (Événement F-WAR - drawer-open).
- Émettre une copie de ticket (Événement C).
- Effectuer un remboursement complet (Événement N, M111) ou partiel (M112B - événement séparé, voir `FLUX_REMBOURSEMENT_FR.md`).
- Activer / désactiver le mode formation (Événements T), uniquement lorsqu'aucune commande avec des lignes n'est ouverte : une table réelle ne peut ainsi jamais être encaissée en formation, ni une commande de formation encaissée comme une vente réelle.
- Clôturer une vente sans paiement (client parti sans payer, événement N sans paiement), en confirmant avec son PIN.
- Démarrer l'assistance à distance (session RustDesk), en confirmant avec son PIN.
- Activer ou couper HubRise (les commandes en ligne), connecter HubRise, reprendre le catalogue et régler les canaux ; rembourser une commande en ligne annulée. Chaque changement de l'interrupteur HubRise est journalisé.
- Changer le plan de salle (les numéros de table, panneau "Plan de salle"). Chaque changement est journalisé en ajout seul.
- Enregistrer l'arrivée et le départ des autres employés, notamment du personnel « Présence seule » (Événement S, `signWorkIn` / `signWorkOut` au nom de l'employé ; refusé en mode formation et pour soi-même).

- Régler le lecteur de badges (désactivé par défaut : « Désactivé », « Lecteur USB » ; interrupteur « Connexion par badge » ; réglages du lecteur USB), lier un badge à un employé en confirmant avec **son propre PIN** (un badge est un moyen de connexion) et retirer le badge d'un employé (sans PIN : retirer ne fait que supprimer un accès). Chaque lien, retrait et changement de réglage est journalisé en ajout seul (`badge_log`, qui, quand). Ces actions sont refusées aux autres profils (`forbidden`).
- Accéder à la page Paramètres (bouton "Config", `SettingsView.vue`) et à la vue Rapports.
- Créer des utilisateurs (Gérant, Serveur, Apprenti ou « Présence seule »), en désactiver ("Désactiver" ; jamais soi-même ; jamais de suppression : l'INSZ reste sur les événements signés) et fixer leur PIN. Créer un Gérant ou changer le PIN d'un autre employé demande le PIN du Gérant connecté.

2.2 Serveur (`Cashier`)

Profil d'opérateur de caisse standard. Peut :

- Se connecter avec sa tuile (ou son INSZ) + code PIN (Événement S - `signWorkIn`, sauf s'il est déjà en service).
- Se connecter avec son badge à la place du PIN, si le Gérant a activé le lecteur et la connexion par badge (même Événement S). Une fois connecté, son propre badge est refusé (`presence_self` : sa présence passe par la connexion et « Fin de service »), mais il peut présenter le badge d'un collègue pour enregistrer la présence de celui-ci (§3).
- Verrouiller l'écran, sans pointer son départ ; pointer son départ ("Fin de service" sur l'écran de connexion, Événement S - `signWorkOut`).
- Ouvrir / réutiliser une table en cours.
- Ajouter, retirer ou modifier les lignes d'une commande ouverte.
- Enregistrer la commande et l'envoyer en cuisine (Événement P - `signOrder`, bon de commande imprimé).
- Imprimer un pré-ticket (Événement P - `signPreBill`).
- Encaisser : encaissement comptant ou carte (Événement N - `signSale`). Tiroir s'ouvre automatiquement pour les paiements comptant. Avec un terminal de paiement relié, "Encaisser sur le terminal" (`eft_pay`) et "Annuler" (`eft_abort`) demandent les mêmes droits que l'encaissement (Gérant, Serveur) ; "Vérifier" un paiement dont la réponse est inconnue (`eft_check`) et la liste des paiements d'une commande sont ouverts à tout utilisateur connecté.
- Réimprimer une seule fois l'original manquant d'un ticket (bouton "Imprimer le ticket" de l'écran de fin).
- Traiter les commandes en ligne : accepter, refuser, terminer, encaisser en espèces ou par carte à la remise, clôturer une commande annulée avant paiement.
- Modifier son propre PIN.

2.3 Apprenti (`Waiter`)

Profil restreint. Peut :

- Se connecter, verrouiller l'écran et pointer son départ.
- Se connecter avec son badge à la place du PIN, si le Gérant a activé le lecteur et la connexion par badge ; présenter le badge d'un collègue pour enregistrer sa présence (§3).
- Ouvrir / réutiliser une table.
- Ajouter, retirer ou modifier les lignes d'une commande ouverte (chaque correction est journalisée et transmise au FDM).
- Enregistrer la commande et l'envoyer en cuisine (Événement P - `signOrder`).
- Faire avancer une commande en ligne : "Préparer", "Prête" et "Retarder".
- **NE peut PAS** imprimer l'addition ni encaisser : les boutons « Addition » et « Payer » ne lui sont pas présentés, et le backend refuse la commande (code `forbidden`) ; un Serveur ou un Gérant encaisse.
- **NE peut PAS** générer de rapport, copier un ticket, rembourser, ouvrir le tiroir, ni modifier les paramètres.

Mode formation. Seul un Gérant l'active (§2.1). Il vaut pour toute la caisse : il n'existe pas de profil "formation". Quand il est actif, un Apprenti prend les commandes comme d'habitude mais ne peut toujours pas encaisser ; ce qu'un Serveur ou un Gérant encaisse est alors un événement de formation (T).

2.4 Présence seule (`Waiter` avec `presence_only`)

Profil du personnel qui n'utilise jamais la caisse (cuisine, plonge) et dont la présence doit pourtant être enregistrée (manuel de certification, §II.E). Ce n'est pas un quatrième rôle : en base, l'employé est un `Waiter` dont la colonne `users.presence_only` vaut 1, ce qui ne lui donne aucun droit supplémentaire. Il :

- n'a **pas de PIN** et n'apparaît pas sur les tuiles de l'écran de connexion ;
- **ne peut pas** se connecter, ni choisir un PIN, ni terminer son service lui-même : le moteur refuse ces commandes avec le code `presence_only_user`, avant toute vérification de PIN ;
- est pointé par un Gérant, depuis "Config", panneau "Employés" (boutons "Arrivée" et "Départ", `commands::social::do_clock_in_employee` et `do_clock_out_employee`), ou par son propre badge (puce suivante) : dans les deux cas l'événement S est signé par le FDM au nom de l'employé ; le Gérant qui l'a enregistré est conservé dans `staff_shifts.started_by` / `ended_by` (vides pour un badge) ;
- peut recevoir un badge (lié par un Gérant avec son PIN) : lorsqu'il le présente sur le lecteur, depuis n'importe quel écran ou sur l'écran de connexion, le moteur enregistre son arrivée ou son départ (`commands::badges::do_badge_tap`, Événement S au nom de l'employé, `started_by` / `ended_by` vides). Un badge ne lui ouvre jamais de session : il n'a ni PIN ni connexion (aucun droit) ;
- peut être désactivé comme tout employé (jamais pendant qu'il est en service : code `deactivate_on_shift`) ; son badge est alors retiré.

3. Mécanismes d'enforcement

L'enforcement vit à deux niveaux :

1. **Niveau commandes du moteur** (couche autoritative, `crates/pos-engine/src/commands/access.rs`). La connexion (`login`, INSZ + PIN, ou badge pour un Serveur ou un Apprenti) ouvre une session côté backend ; la déconnexion (`logout`, après le pointage de sortie) la ferme. Chaque commande qui signe un événement fiscal, modifie un paramètre ou gère les utilisateurs vérifie d'abord le rôle de l'opérateur connecté :

Accès	Rôles	Commandes
Personnel	Gérant, Serveur, Apprenti	pointage (S), commandes et lignes, enregistrement de commande (P), commandes en ligne : préparation, "Prête" et retard
Encaissement	Gérant, Serveur	addition (P), vente (N), impression d'un original manquant, commandes en ligne : acceptation, refus, remise, encaissement et clôture
Gestion	Gérant	remboursement, copie (C), mouvements de caisse et tiroir (F), rapports X/Z (R), mode formation, utilisateurs (création, désactivation, PIN des autres), pointage d'un autre employé (S), retrait d'un badge, réglages du lecteur de badges, remboursement d'une commande en ligne, interrupteur, catalogue et canaux HubRise, sauvegarde

Accès	Rôles	Commandes
Gestion avec PIN	Gérant, PIN de l'opérateur confirmé	vente clôturée sans paiement, démarrage de l'assistance à distance, création d'un Gérant, PIN d'un autre employé, lien d'un badge à un employé

Une commande refusée renvoie le code `not_logged_in` (aucune session) ou `forbidden` (rôle insuffisant) avant tout appel au FDM : aucun compteur ni aucune donnée n'est modifié. L'écran affiche le message correspondant dans la langue de l'interface (« Session fermée : reconnectez-vous. », « Action réservée à un autre profil. »), voir `crates/pos-engine/src/commands/errors.rs`.

2. **Niveau UI** (`ui/src/stores/auth.ts`) : les boutons et écrans qu'un rôle ne peut pas utiliser ne lui sont pas présentés (Payer et Addition pour l'Apprenti ; Rapports et Config pour l'Apprenti et le Serveur). Cette couche est purement ergonomique.

L'INSZ de chaque événement est celui de l'opérateur connecté : une commande qui nomme un autre opérateur (remboursement, copie, mouvement de caisse, rapport, ou le pointage « personnel » `work_in` / `work_out`) est refusée (code `not_the_operator`). Seule exception, voulue : un Gérant peut pointer un autre employé avec `clock_in_employee` / `clock_out_employee`, et l'événement S est alors signé au nom de cet employé (§2.4, §4). Une vente est signée au nom du Serveur ou du Gérant qui encaisse, même si la commande a été prise par un autre membre du personnel.

Ces règles sont couvertes par `crates/pos-engine/tests/access_control.rs` (chaque rôle, chaque commande, sessions, PIN, formation).

4. Journal des accès

Chaque connexion d'un employé qui n'est pas encore en service (Événement S - `signWorkIn`) et chaque fin de service (Événement S - `signWorkOut`) est consignée dans la table `fiscal_events` avec : - `event_type = 'S'` - `user_insz` = INSZ de l'opérateur - `created_at` = horodatage de l'événement - `fdm_response_json` = réponse signée du FDM

Pour le personnel « Présence seule », ou lorsqu'un Gérant pointe un autre employé, `user_insz` est l'INSZ de l'**employé** pointé (comme dans les cas d'usage M140 et M141) ; le Gérant qui a fait l'enregistrement est conservé dans `staff_shifts.started_by` / `ended_by`, pas dans la requête envoyée au FDM.

Pour un pointage par badge (`commands::badges::do_badge_tap`), `user_insz` est l'INSZ du **titulaire du badge** (même événement S que M140 et M141) et `started_by` / `ended_by` restent vides, l'employé s'étant enregistré lui-même ; le passage est consigné à part dans `badge_scans` (heure, résultat, INSZ, référence de 12 caractères de l'empreinte du badge, jamais son numéro). Les liens, retraits et changements de réglage sont dans `badge_log`, avec le Gérant qui les a faits.

Ces lignes constituent le **journal Dimona-compatible** exigible par l'ONSS et utilisable pour reconstruire intégralement les heures de présence du personnel.

5. Politique de mots de passe

- Les PINs sont stockés sous forme de hash bcrypt (coût 12) dans la colonne `users.pin_hash`. Le PIN lui-même n'est jamais stocké en clair ni journalisé.
- Un Gérant (`admin`) a toujours un PIN : sans PIN, la caisse refuse sa connexion et lui fait choisir un PIN (saisi deux fois), enregistré en même temps que la session s'ouvre (`commands/auth.rs::do_login_with_new_pin`). Une fois choisi, ce chemin est refusé : personne ne peut s'approprier une tuile qui a déjà un PIN. Ce choix à l'écran de connexion n'existe que tant qu'aucun Gérant n'a de PIN (première mise en service) : ensuite, un Gérant sans PIN reçoit le sien d'un autre Gérant dans Paramètres (`first_pin_needs_manager` à l'écran de connexion), et un nouveau Gérant est créé avec son PIN, confirmé par le PIN du Gérant qui le crée.

- Après 5 PIN incorrects de suite pour un même employé (connexion ou confirmation par PIN), la caisse refuse tout essai, même le bon PIN, pendant 30 secondes, puis le double à chaque nouvel échec, jusqu'à 15 minutes (`pin_locked`, avec le temps restant à l'écran). Un PIN correct remet le compteur à zéro ; un redémarrage aussi (`commands/access.rs::verify_pin`).
- Pour un Serveur ou un Apprenti, le PIN n'est pas obligatoire (utile pour un apprenti en période d'essai) ; un avertissement s'affiche à chaque connexion sans PIN. Le drapeau `has_pin` (calculé) informe le frontend de présenter ou non le pavé numérique de PIN.
- L'identité système `00000000029` (robot, enregistrements automatiques) ne peut jamais ouvrir de session et n'a pas de tuile.
- **Connexion par badge.** Désactivée par défaut. Quand le Gérant l'a activée (réglage « Connexion par badge » du panneau « Lecteur de badges »), un Serveur ou un Apprenti peut ouvrir sa session avec son badge sans PIN, par la même procédure que la connexion par PIN moins la vérification du PIN (`commands::badges::do_badge_tap`). Un **Gérant ne se connecte jamais avec un badge seul** : son badge sélectionne son compte et ouvre son clavier de PIN (`pin_required`), la session étant ouverte par la connexion habituelle (INSZ + PIN, verrouillage compris) ; aucune action réservée au Gérant (remboursement, copie, mouvements de caisse, rapports, Z, réglages, utilisateurs, badges) n'est donc possible sans son PIN. Un employé « Présence seule » ne se connecte pas non plus : son badge n'enregistre que sa présence. Un badge scanné n'est pas une activité de l'opérateur connecté (le verrouillage automatique n'est pas repoussé). Un employé peut refuser le badge : son PIN reste valable.
- **Stockage des badges.** Seule une empreinte HMAC-SHA256 du numéro du badge est stockée (table `staff_badges`, une empreinte active par employé et par badge, jamais supprimée : un retrait ne fait que dater la ligne), avec une clé propre au terminal (`badge.key`, hors de la base, des sauvegardes et de l'export). Voir *SECURITE_BD_FR.md*.

6. Limitations connues

- Un employé « Présence seule » ne peut pas devenir utilisateur de la caisse par modification : le Gérant le désactive (après avoir enregistré son départ) puis le crée à nouveau avec le même INSZ et le profil voulu (réactivation de l'INSZ existant).
- Pas de distinction entre Gérant et Technicien : les deux utilisent le rôle `admin`. Le manuel SCE 2.0 ne les distingue pas dans la matrice de capacités ; les deux profils ont accès complet.